

# Quantification du SCR lié à la non-conformité au règlement DORA (UE 2022/2554)

Une cascade dirigée entre les cinq piliers

*Présenté par : Kélian KADDOURI*

*ENSAE Paris, filière Actuariat · Nexialog Consulting*

*[jj / mm / 2026]*

*Sous la supervision de :*

**M. Hugo RAPIOR**

*Tutrice académique :*

**Caroline HILLAIRET**



# SOMMAIRE

**01**

**Le vide prudentiel**

**02**

**La donnée et sa frontière**

**03**

**La cascade dirigée**

**04**

**Borner plutôt que poser**

**05**

**Quatre canaux et le capital**

**06**

**Décision, limites et suites**

# DORA impose une maîtrise, aucun dispositif n'en fait du capital

## Règlement (UE) 2022/2554, applicable depuis janvier 2025

### ① Un déplacement du centre de gravité prudentiel

- Bâle, puis Solvabilité II, puis DORA : de la couverture financière du risque vers la continuité opérationnelle
- DORA ne remplace pas l'exigence de capital, il en révèle l'angle mort : la dynamique propre des défaillances technologiques

### ② L'espace laissé libre par Solvabilité II

- Dans la Formule Standard, la charge opérationnelle est forfaitaire : elle n'exprime rien de l'état de conformité de l'entité
- Un score qualitatif de conformité ne dit rien du capital qu'une direction des risques doit immobiliser
- Le secteur conserve en revanche le choix méthodologique, et c'est cet espace que le mémoire occupe

### ③ Le maillon manquant, étape par étape

|                |                                    |
|----------------|------------------------------------|
| Non-conformité | à un ou plusieurs des cinq piliers |
| Incident TIC   | défaillance, puis propagation      |
| Perte          | opérationnelle et cyber            |
| Capital        | exigence de couverture             |
| Décision       | remédier, détenir ou transférer    |



### Besoin de capital ORSA au titre de DORA

La Formule Standard donne le même chiffre à une entité exemplaire et à une entité défaillante : c'est la définition d'un angle mort.

**Message clé** une exigence de maîtrise sans traduction prudentielle, et c'est le vide que ce travail comble.

# Une question en deux temps, et trois apports

## Ce qui se chiffre, et ce qui peut être affirmé

**Combien coûte en capital de ne pas se conformer à DORA, et jusqu'où ce chiffre peut-il être affirmé ?**

### Méthodologique

Une cascade dirigée entre domaines de contrôle, trois propriétés démontrées

### Empirique

Une frontière d'identifiabilité : ce que la donnée ne dit pas, et ce qu'elle ne dira jamais

### Opérationnelle

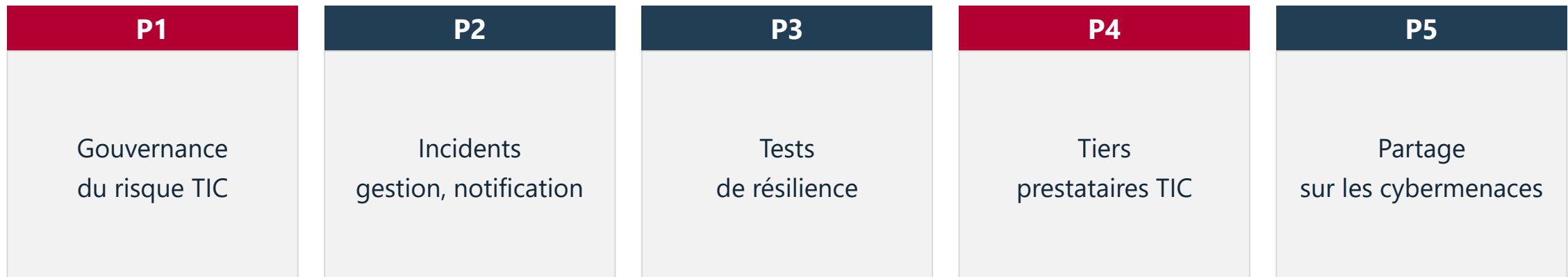
La donnée manquante devient une exigence de reporting, hiérarchisée par son apport

**La seconde moitié de la question fait le travail : elle interdit de publier une précision que la donnée ne porte pas.**

**Message clé** répondre à la première moitié sans la seconde produirait un chiffre indéfendable.

# Cinq domaines de contrôle, pas cinq cases à cocher

**Et la défaillance de l'un dégrade la tenue des autres**



Une gouvernance défaillante retarde la détection des incidents ; une dépendance non maîtrisée ouvre une porte que les tests n'ont pas explorée ; un partage d'information absent prive des trois autres.

**En rouge, les deux piliers qui émettent le plus dans la matrice calibrée.**

**Message clé** la non-conformité ne reste pas dans son pilier, elle se propage, et c'est ce que le modèle doit porter.

# La donnée montre la co-occurrence, jamais la direction

## Sept sources, et chacune avec son statut de preuve déclaré

### Observable

- Fréquence des incidents, par année et par entité
- Sévérité des pertes, en euros, au-delà d'un seuil
- Co-occurrence entre piliers dans un même sinistre
- Structure du risque par vecteur d'attaque

### Non identifiable

- La DIRECTION de la contagion
- Quel pilier entraîne l'autre
- Une matrice et sa transposée sont indistinguables
- Et elles donnent pourtant un capital différent

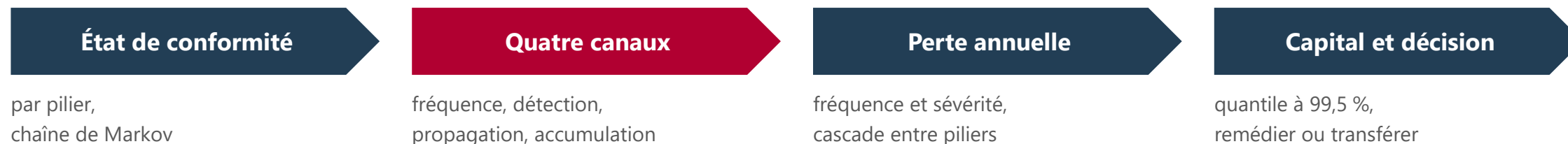
Deux statuts de preuve sont distingués dans tout le document : la donnée versionnée et rejouable, et la citation externe non recalculable.

**Cette limite n'est pas un manque de données à combler par plus de données du même type : elle est structurelle, et elle commande la suite.**

**Message clé** la frontière est dans la nature de l'observable, pas dans la taille de l'échantillon.

# D'un état de conformité à une décision, en quatre étapes

## Deux canaux calibrables, deux canaux bornés



### ① Calibrés sur données

- Fréquence des incidents
- Taux de détection des pertes

Ces deux canaux portent un intervalle estimé.

### ② Bornés, non calibrés

- Gain de propagation entre piliers
- Accumulation par prestataire commun

Ces deux canaux portent un scénario borné, et leur part n'est pas un budget de remédiation.

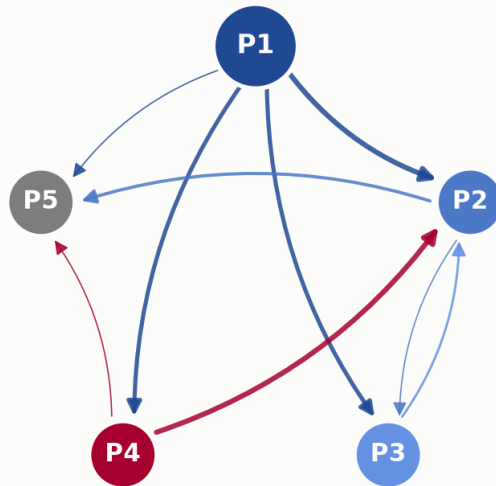
**Message clé** le modèle est partiellement calibré et partiellement borné, et le document dit lequel est lequel.

# L'ordre de propagation change la criticité

## Ce qu'une structure de dépendance symétrique ne peut pas voir

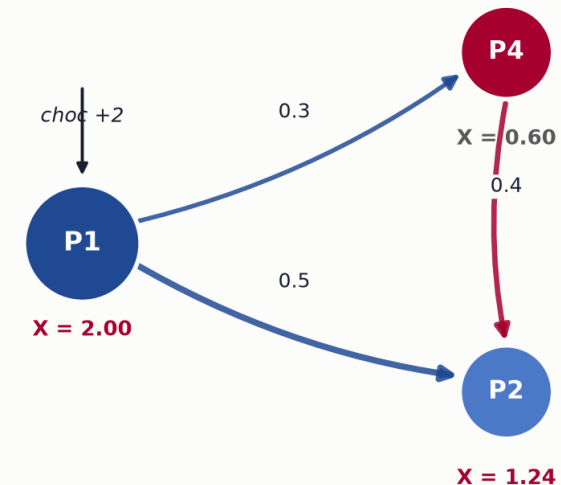
La propagation dirigée  $W$  : qui entraîne qui, et de combien

(A) Le réseau dirigé  $W$  (structure de TRANS)



flèche  $i \rightarrow j$  =  $i$  entraîne  $j$  ; épaisseur  $\propto$  force. P1 émet fort, reçoit peu  $\rightarrow$  asymétrie.

(B) Cascade d'un choc +2 sur P1 (exemple chiffre)



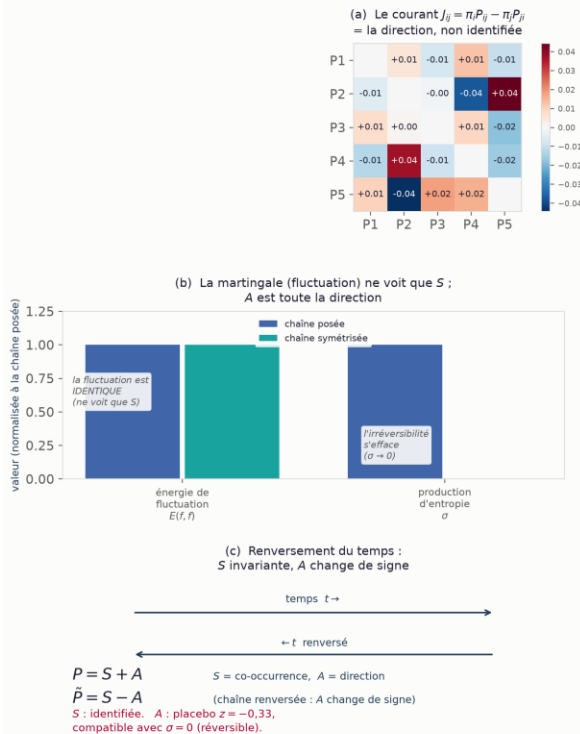
seuil  $K = 1 \rightarrow$  P1 et P2 déclenchent, pas P4.  
Même choc place sur P2  $\rightarrow$  reste local (1 seul incident).

**Message clé** une copule capture la co-occurrence des pertes, mais symétriquement : elle ne distingue pas ce qui entraîne de ce qui subit.

# La direction n'est pas identifiable, et c'est un résultat

## Le coeur du mémoire

Z11 : la direction A est le courant irréversible d'un processus, ce que la martingalisation retire et que la co-occurrence ne voit pas



La matrice se décompose en une partie symétrique et une partie antisymétrique.

**La donnée identifie la première, la co-occurrence.**

**Elle n'identifie pas la seconde, la direction.**

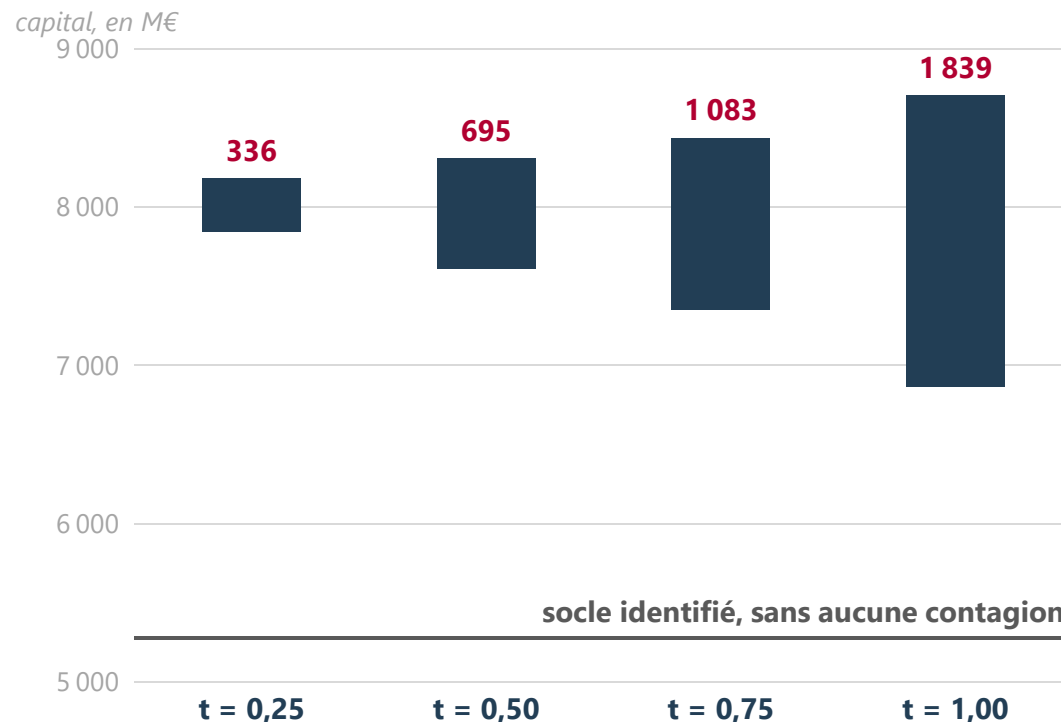
Une matrice et sa transposée sont indistinguables pour la donnée, et donnent pourtant un capital et une décision différents.

Ce n'est pas un échec du modèle : c'est ce qui interdit de publier une direction comme si elle avait été observée.

**Message clé** un résultat d'identification, et non une limite de l'estimation.

# Du point à la bande : borner plutôt que poser

## Identification partielle sur l'ensemble des matrices admissibles



*t : ignorance sur la direction, 1 = état actuel des données*

Plutôt que de poser la direction, le capital est borné sur l'ensemble des matrices compatibles avec ce que la donnée identifie.

### 1 024 sommets, énumérés exhaustivement

En rouge, la largeur de la bande. Elle croît linéairement avec l'ignorance, et son maximum est connu d'avance : c'est plus favorable qu'un intervalle de confiance ordinaire.

Le point d'expert, 8 110 M€, est un point de cet ensemble, jamais sa mesure.

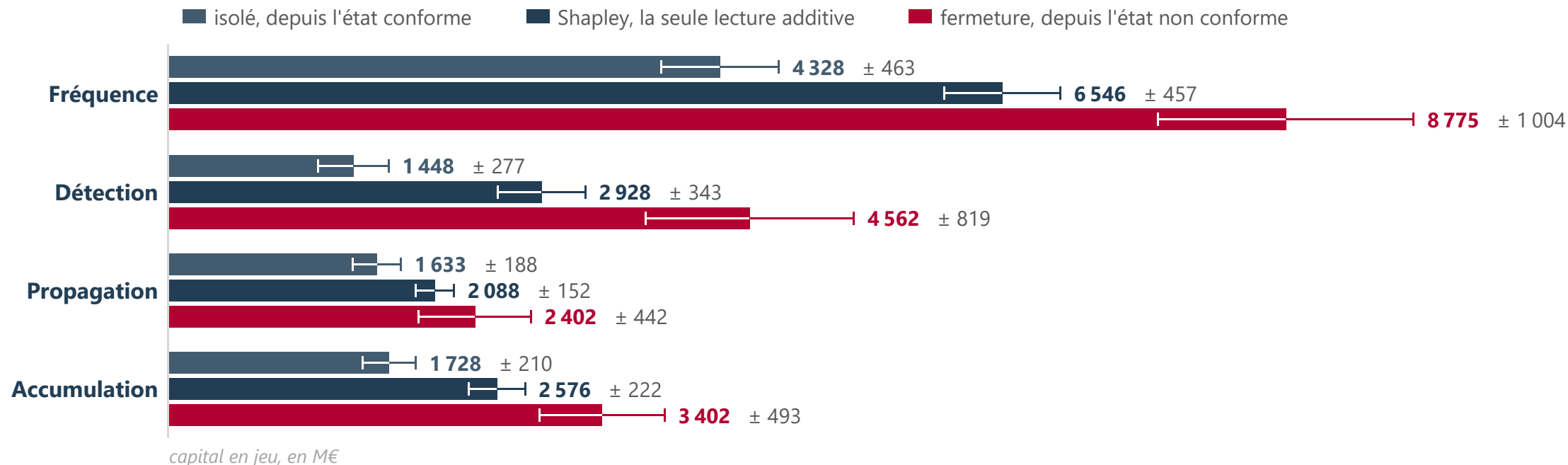
**Le niveau affiché reste illustratif.**

**Message clé** la bande quantifie une incertitude structurelle au lieu de la masquer derrière un point.

# Quatre canaux déplacés, et leurs effets ne s'additionnent pas

## Au secteur, et non à l'échelle d'une entité

Au secteur, le besoin de capital passe de 6 049 à 20 188 M€, soit un facteur 3,34. La non-conformité n'ajoute aucune pénalité : elle déplace quatre paramètres de la loi de perte.



Canaux isolés **9 138 M€**

Écart total **14 139 M€**

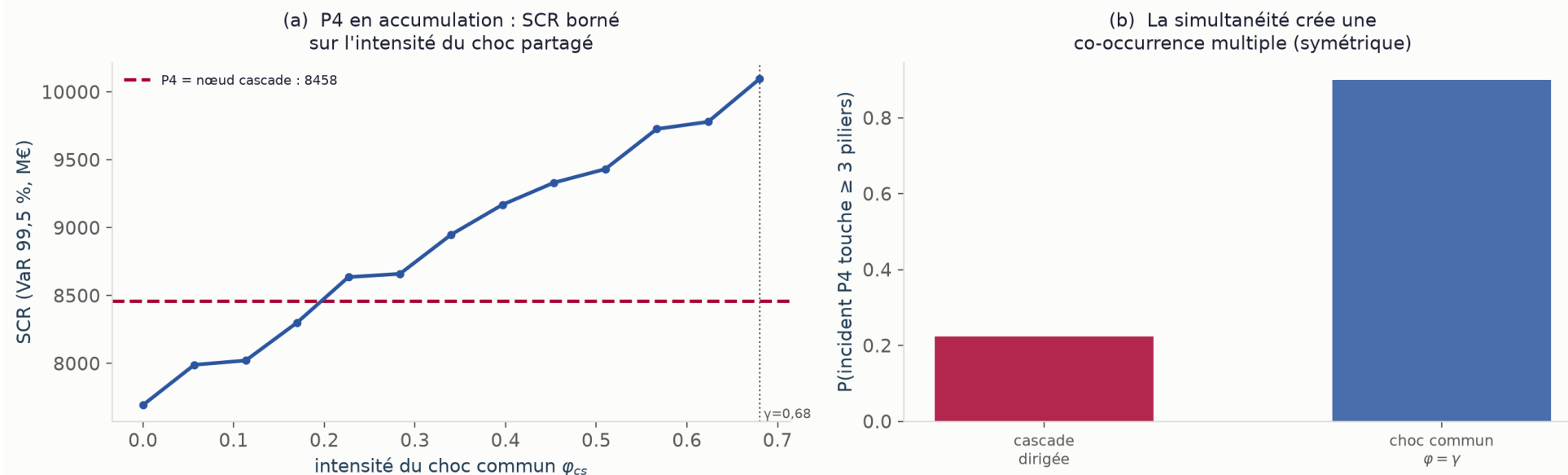
Interaction **5 001 M€, soit 35 %**

**Message clé** remédier un canal rapporte davantage à une entité défaillante partout : c'est la lecture de fermeture qu'un plan doit citer.

# Le pilier des tiers concentre, il ne propage pas seulement

## Contagion et accumulation sont deux mécanismes distincts

### Z9 : le pilier tiers comme nœud d'accumulation, dans la partie identifiée



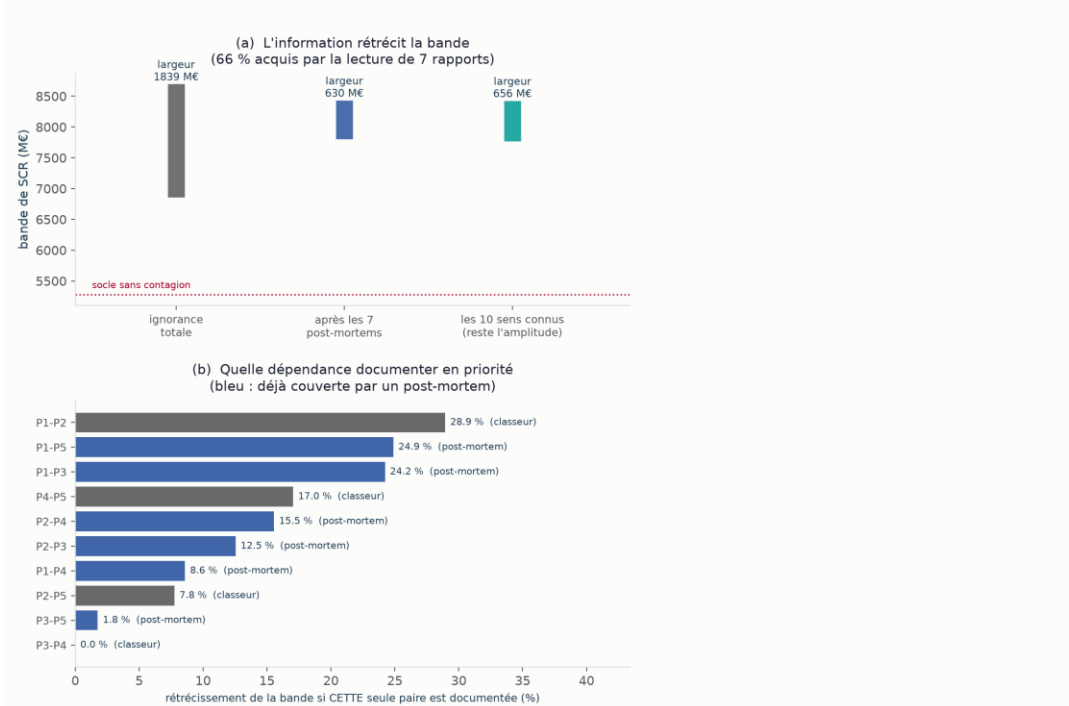
Un prestataire commun crée un choc partagé entre entités : ce n'est plus de la contagion d'un pilier vers un autre dans une même entité, c'est de l'accumulation.

**Message clé** c'est exactement ce que DORA demande de cartographier : la dépendance à des prestataires TIC critiques.

# La donnée manquante devient une exigence de reporting

## Le registre d'incidents comme instrument de capital

Z18 : la valeur de l'information manquante, chiffrée et hiérarchisée : quelle dépendance le registre DORA devrait documenter d'abord



### ① Quatre champs, hiérarchisés par ce qu'ils resserrent

**Horodatage des incidents**

**Domaine de contrôle touché**

**Cause commune consolidée**

**Champs renseignés obligatoires**

Le modèle ne dit pas seulement qu'il manque une donnée : il dit laquelle, et ce qu'elle rapporte en resserrement de bande.

**Message clé** chaque champ renseigné resserre la bande, et la limite de données devient un livrable.

# Trois décisions, et une confusion à ne pas commettre

Ce que la borne autorise, et ce qu'elle n'autorise pas

| Remédier                                                     | Détenir                                                         | Transférer                                   |
|--------------------------------------------------------------|-----------------------------------------------------------------|----------------------------------------------|
| Prioriser les canaux calibrables :<br>fréquence et détection | Le capital immobilisé coûte<br>chaque année, pas une seule fois | Comparer au prix de marché<br>du même risque |

**Une borne de capital n'est pas un budget de remédiation : deux des quatre canaux sont des bornes posées, et leur part n'est pas une enveloppe à dépenser.**

Le bénéfice d'une remédiation a deux composantes, et la plus grosse n'est pas le capital libéré mais la perte évitée.

**Message clé** le retour calculé sur le seul portage de capital est un majorant, pas un plancher.

# Ce que ce travail n'établit pas, et ce qui tient malgré cela

**Les deux colonnes se présentent ensemble, jamais la gauche seule**

## Non établi

- La direction de contagion n'est pas identifiée
- Le niveau absolu est illustratif, et c'est une borne supérieure à l'échelle d'une entité
- L'incertitude de queue est large
- Deux canaux sur quatre sont bornés, non calibrés
- Le niveau de sévérité dérive dans le temps, et le backtest le mesure

## Établi malgré cela

- Le signe et l'ordre de l'écart entre états
- La hiérarchie des piliers par contribution
- Le cadre de bornage et son coût, mesuré
- La recommandation de reporting et sa priorité
- La loi de comptage et la forme de la queue, validées hors échantillon

**Une thèse de départ a été réfutée par son auteur, et un chiffre d'entité requalifié en borne supérieure. Ce sont des résultats.**

**Message clé** ces limites sont publiées, pas concédées, et c'est ce qui rend le reste défendable.

# Trois messages

## Et la réponse à la question posée en ouverture

- 1. La non-conformité à DORA se traduit en coût de risque et en capital**  
par le déplacement de quatre paramètres de la loi de perte, et non par une pénalité ajoutée
- 2. La dépendance directionnelle ne doit pas être calibrée sur des données qui ne l'identifient pas**  
d'où une bande, et le coût de l'ignorance mesuré plutôt que masqué
- 3. La limite de données devient une recommandation actionnable**  
pour l'entité comme pour le régulateur, hiérarchisée par ce que chaque champ rapporte

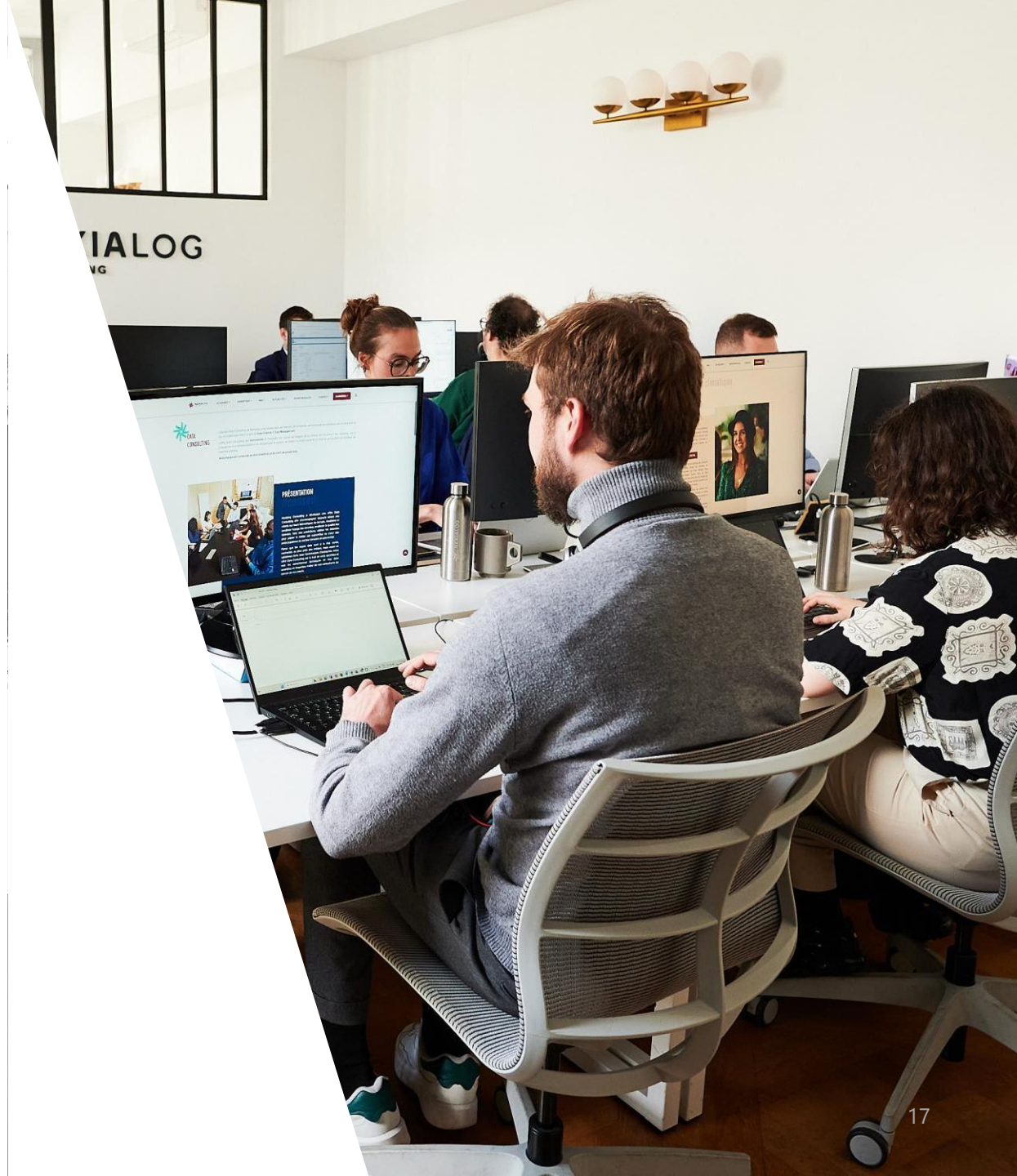
**Quand la dépendance n'est pas identifiable, la bonne réponse actuarielle n'est pas la fausse précision : c'est une borne, une hiérarchie de données et une décision mieux informée.**

# Merci pour votre attention

## Des questions ?

---

Dix diapositives de sauvegarde suivent : sources, paramètres, sévérité, cascade, identifiabilité, bande, canaux, tiers, limites, glossaire.



THINK SMART  ACT DIFFERENT

---

# Annexes

# Sept sources, et chacune avec son statut de preuve

## Ce qui est rejouable, et ce qui ne l'est pas

| Source                                        | Ce qu'elle porte dans le modèle                             | Statut de preuve            |
|-----------------------------------------------|-------------------------------------------------------------|-----------------------------|
| Base internationale de pertes opérationnelles | la sévérité en euros, au-delà du seuil                      | <b>versionné, rejouable</b> |
| Chronologie de brèches                        | la fréquence, et l'étude d'événement MOVEit                 | <b>versionné, rejouable</b> |
| Corpus de rapports post-mortem                | la structure de la direction, et son biais mesuré           | <b>versionné, rejouable</b> |
| États réglementaires publiés                  | quatre bilans réels, anonymisés, pour la descente d'échelle | <b>versionné, rejouable</b> |
| Comptage d'incidents par vecteur              | la structure du risque, jamais son niveau                   | <b>citation externe</b>     |
| Étude de marché de la cyberassurance          | le contexte, et aucune calibration                          | <b>citation externe</b>     |
| Préprint de cascade climatique                | le protocole, jamais l'ordre du résultat                    | <b>citation externe</b>     |

Une citation externe est une valeur qu'aucun script du dépôt ne reproduit. Elle est déclarée comme telle, elle n'entre dans aucune calibration, et elle ne porte aucun niveau de capital.

# Les paramètres, et ce qui est estimé, posé ou gelé

**La thèse dépend de l'ordre, pas du niveau**

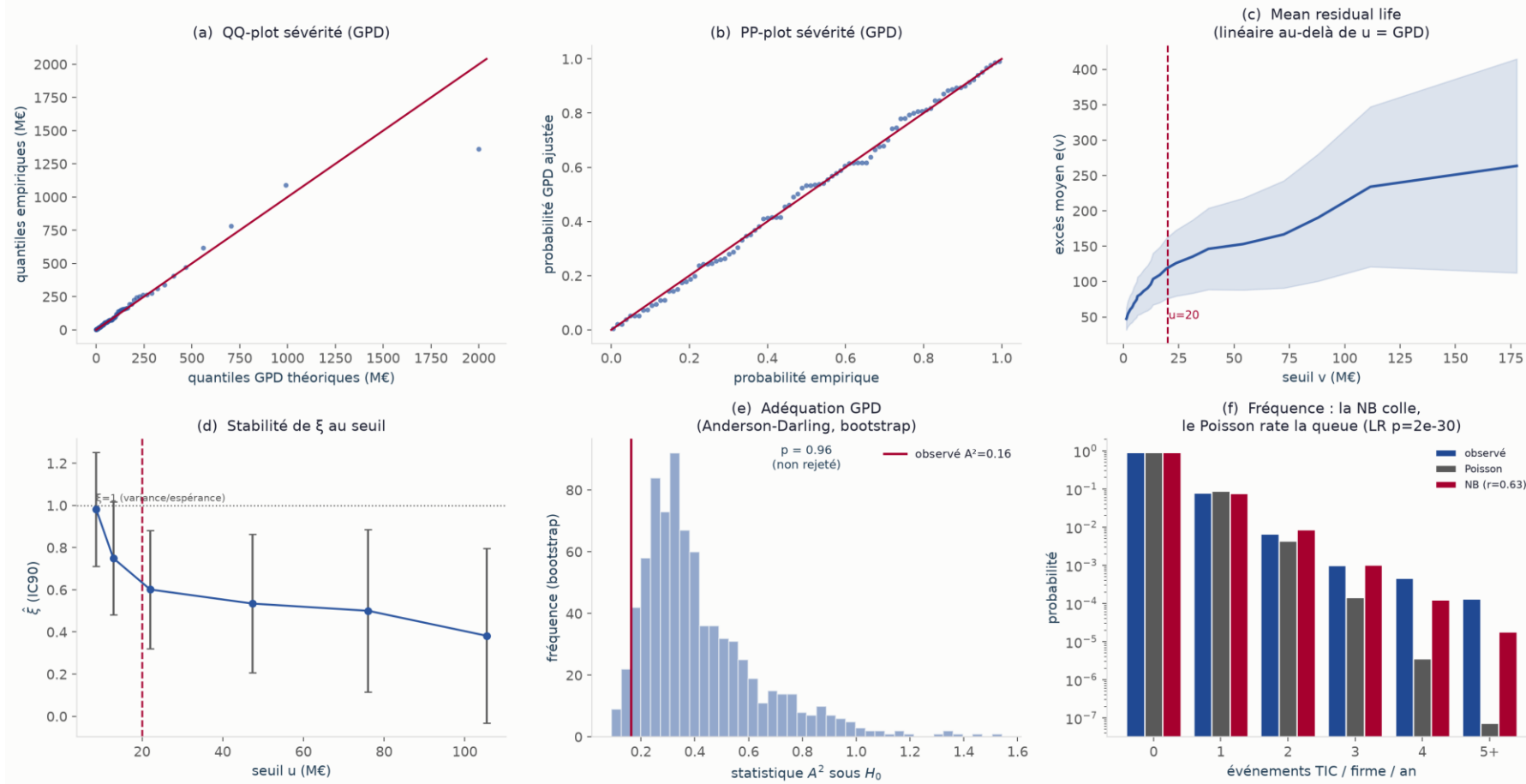
| Paramètre                       | Valeur             | Statut         | Ce que le statut engage                                             |
|---------------------------------|--------------------|----------------|---------------------------------------------------------------------|
| Seuil de la loi de queue, $u$   | 20,03 M€           | <b>posé</b>    | règle du percentile 85 ; la règle de stabilité retombe dessus       |
| Excès au-dessus du seuil        | 91                 | <b>compté</b>  | une fois le seuil et l'échantillon fixés                            |
| Indice de queue, $\xi$          | 0,5954             | <b>estimé</b>  | IC 90 % [0,304 ; 0,831], et c'est la plus grosse incertitude        |
| Échelle, $\sigma$               | 57,97 M€           | <b>estimé</b>  | maximum de vraisemblance, seuil imposé                              |
| Fréquence au secteur, $\lambda$ | 21,56 par an       | <b>calibré</b> | descente d'échelle depuis le périmètre financier                    |
| Surdispersion des comptes       | 9,2                | <b>posé</b>    | marge prudentielle assumée, et déclarée comme telle                 |
| Gain de propagation, $g$        | 0,45 / 0,68 / 0,90 | <b>posé</b>    | le capital est croissant en $g$ : l'ordre suffit à produire l'écart |
| Taux de dépassement, $p_u$      | 0,1509             | <b>gelé</b>    | écart de +2,4 % sur la VaR, chiffré plutôt que corrigé              |

**Ce qui est POSÉ n'est pas une estimation déguisée : la thèse ne dépend pas du niveau de ces valeurs mais de leur ORDRE, et la monotonie du capital en  $g$  est démontrée.**

# Pourquoi une loi de valeurs extrêmes pour la sévérité

## Adéquation, et ce que le backtest valide

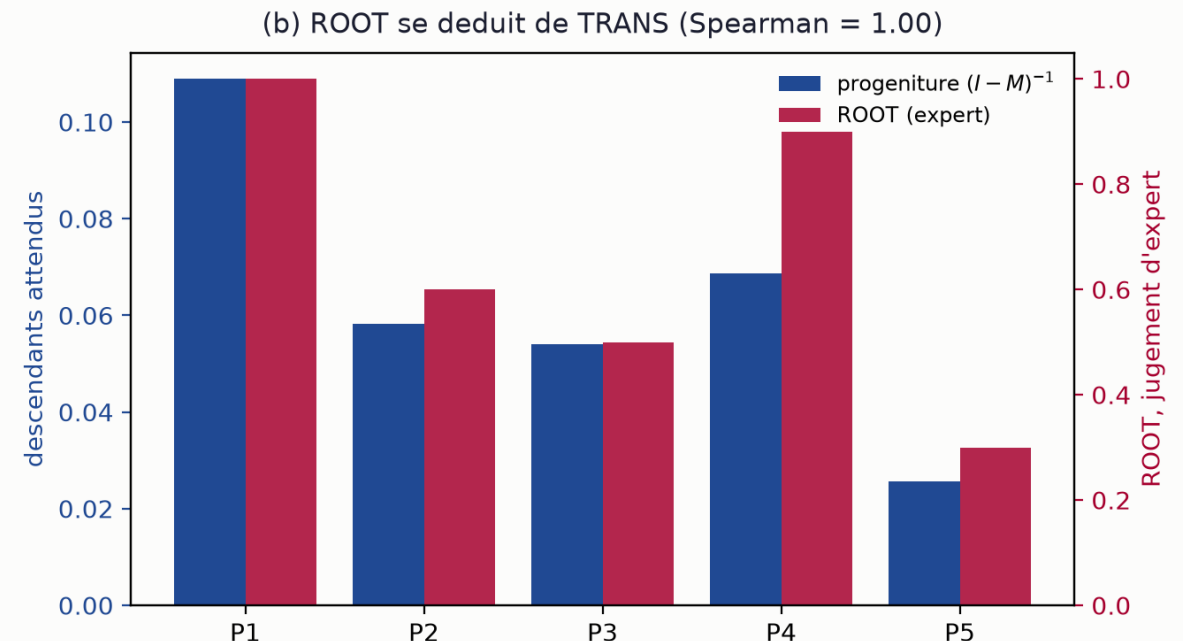
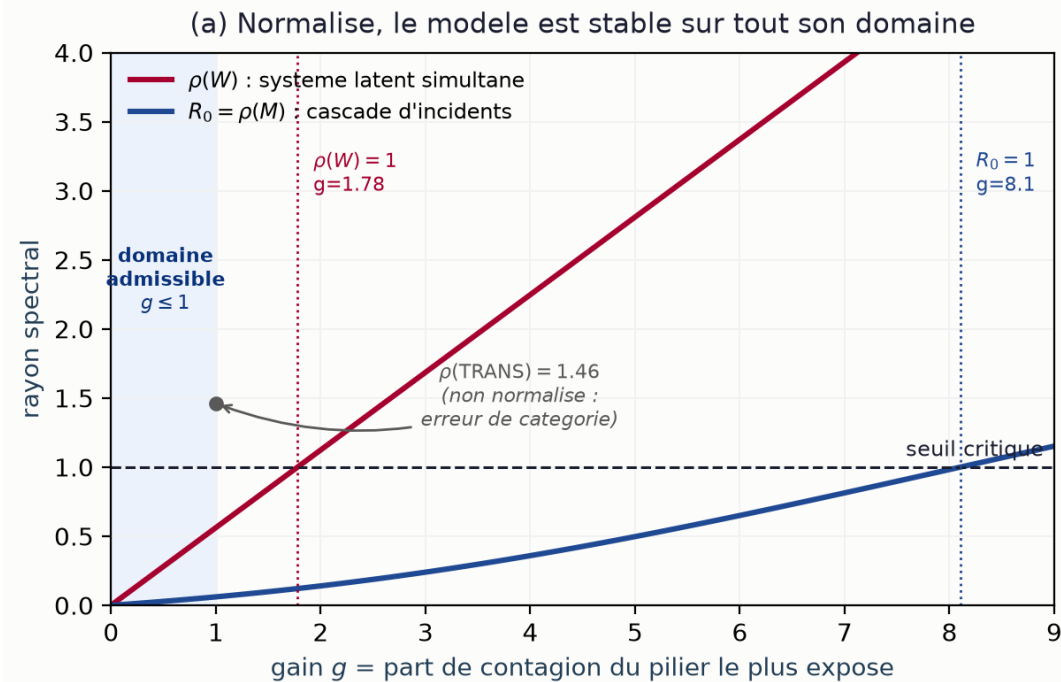
J3 : validation et adéquation du socle : la sévérité GPD et la fréquence NB passent les tests



# La cascade est un processus de branchement sous-critique

## Rayon spectral et taux de reproduction

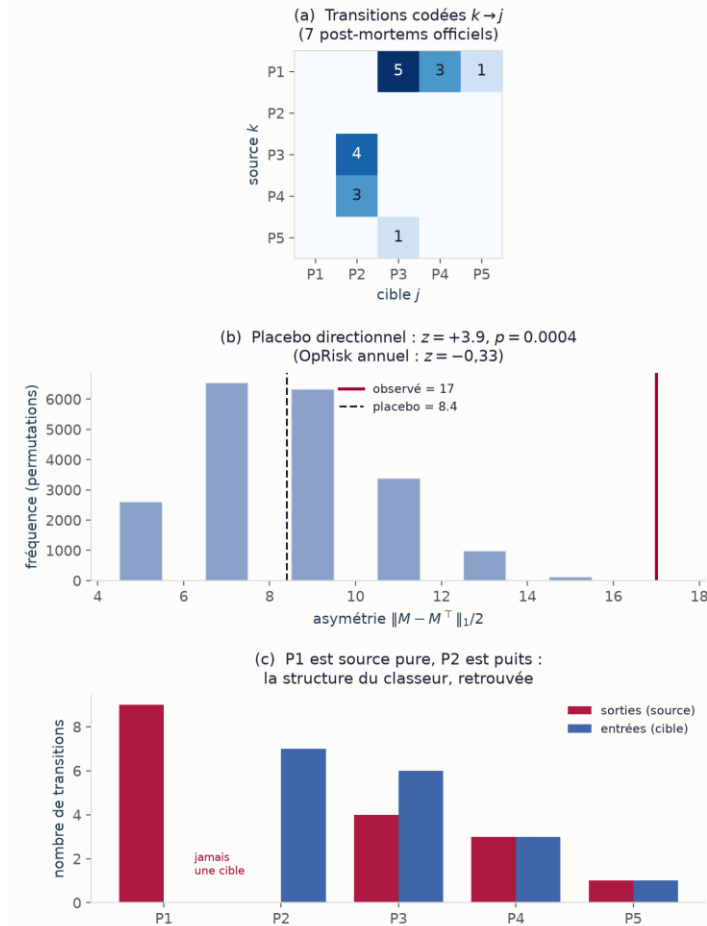
### K3 : la cascade est un processus de branchement



# Ce que le corpus documentaire corrobore, et ce qu'il ne lève pas

**Le biais de narration est mesuré, borné, et non levé**

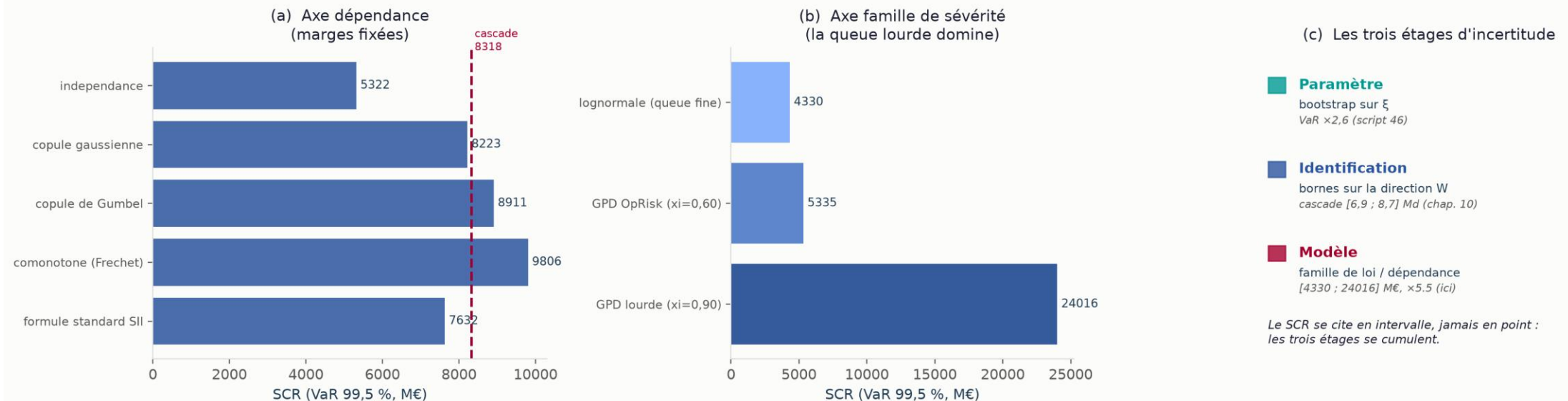
**Z17 : la direction de  $W$  identifiée par codage de post-mortems officiels, là où les bases agrégées échouaient**



# La bande de capital et ses trois étages d'incertitude

Trois sources à ne jamais fondre en une seule barre

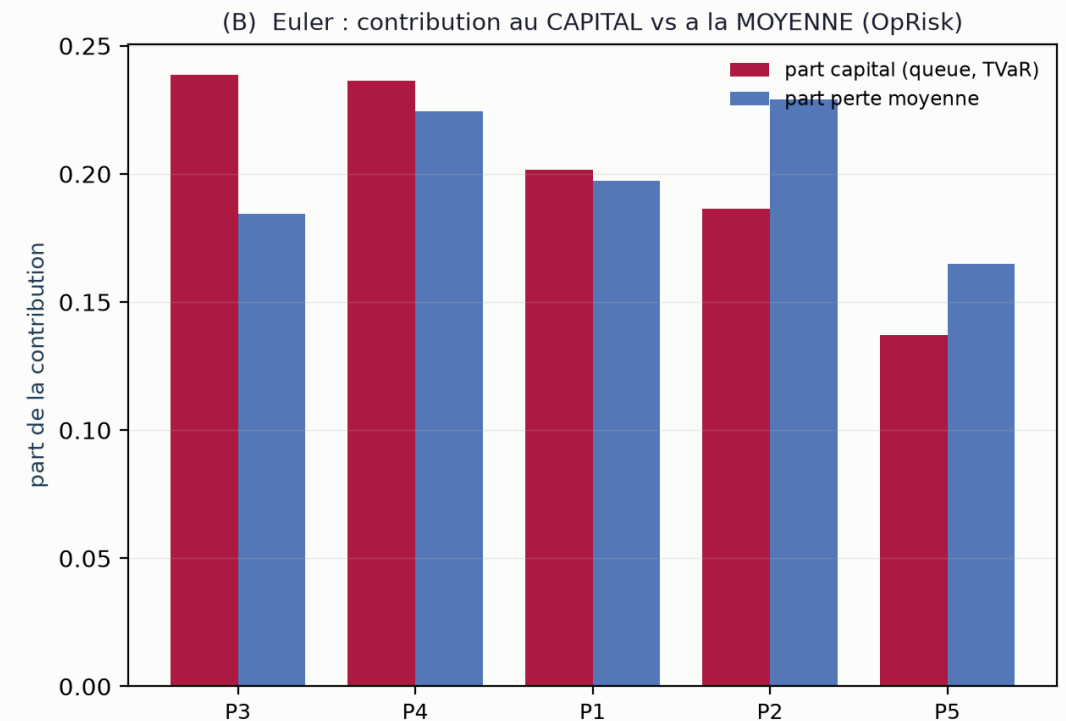
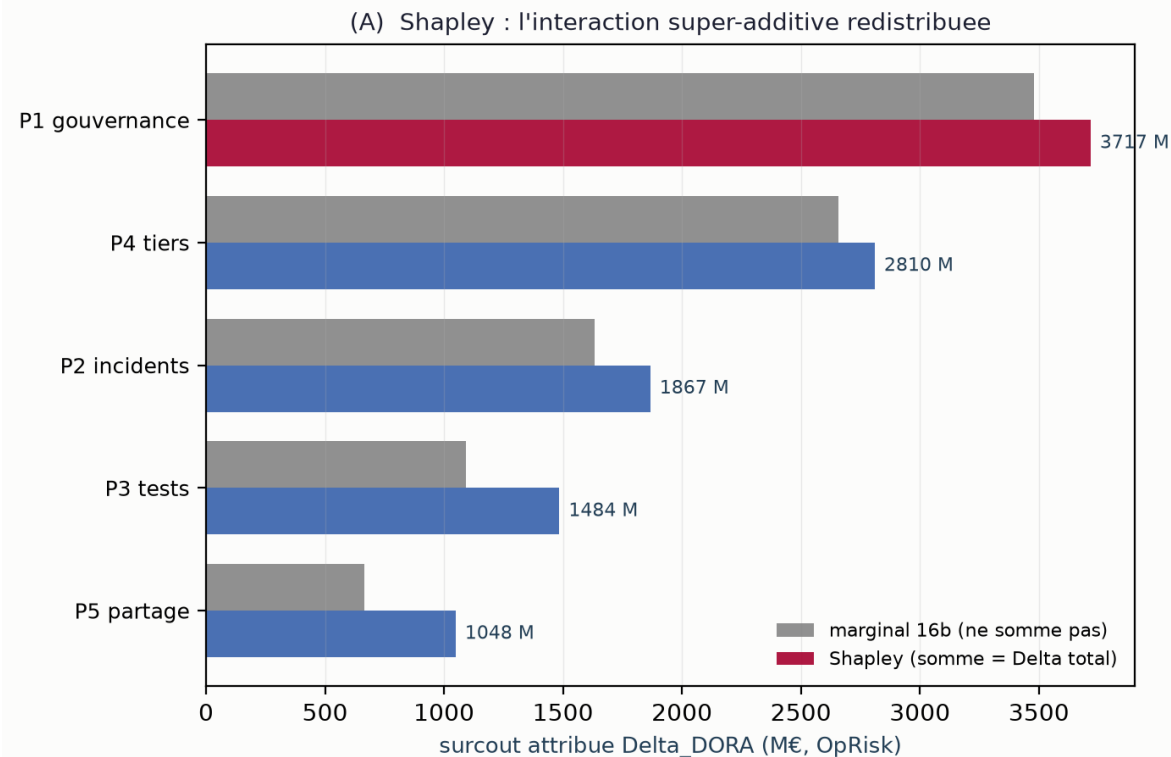
J4 : la bande de modèle, troisième étage d'incertitude ; le niveau bouge selon la famille, l'ordre d'amorce ne bouge pas



# L'attribution par canal : trois lectures non interchangeables

## Isolée, fermeture et Shapley répondent à trois questions

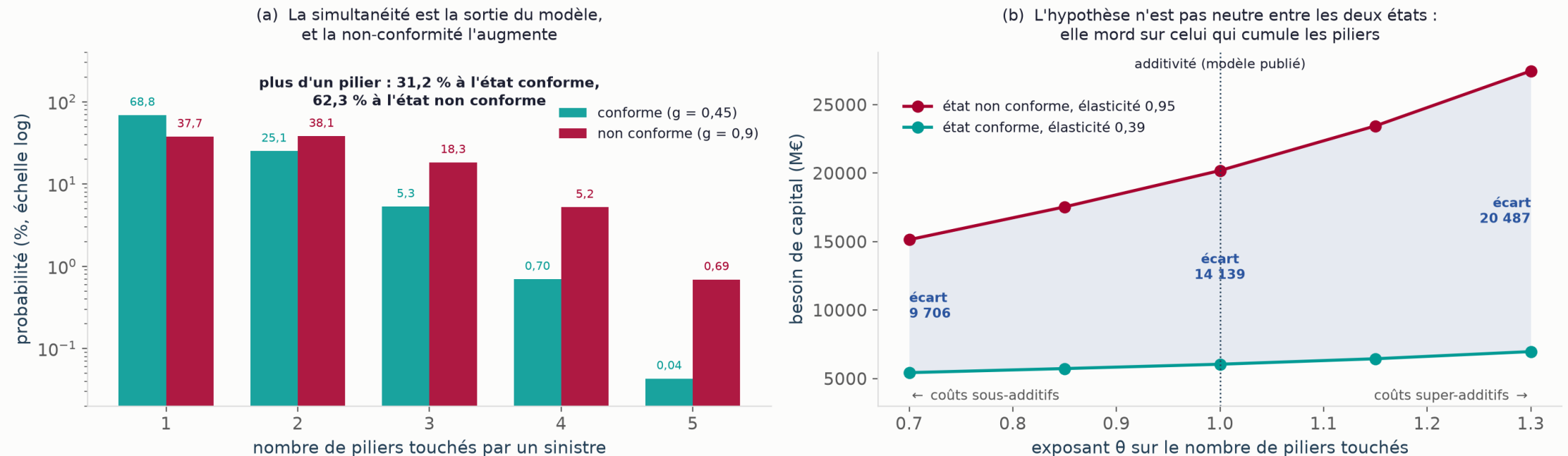
### Allocation du capital DORA aux piliers : Shapley (surcoute) et Euler (niveau)



# Défaillances simultanées : une sortie du modèle, pas une lacune

La loi est exacte, par énumération de la progéniture

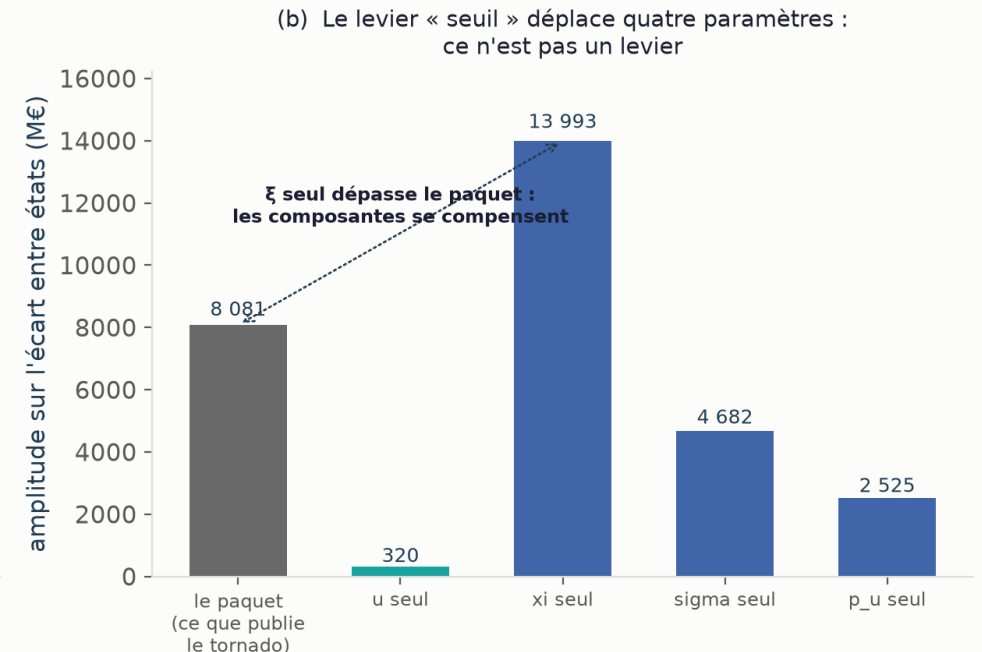
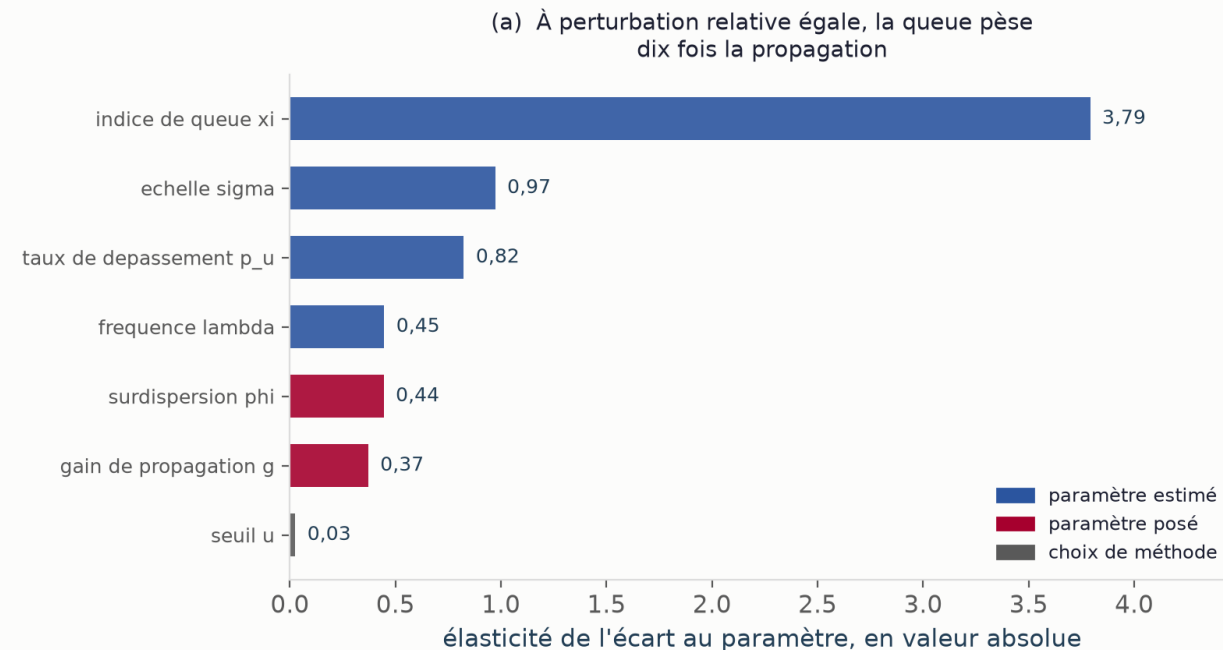
**S30 : les défaillances simultanées sont la sortie du modèle, et l'additivité de leurs coûts est son hypothèse non testée la plus lourde**



# Les hypothèses, par ordre de ce qu'elles coûtent

La fragilité est dans la queue, pas dans la contagion

S32 : le tornado renormalisé, et ce que l'ancien classement devait à ses pages



# Glossaire

## Et la distinction qui a produit une confusion en séance

- DORA : règlement européen sur la résilience opérationnelle numérique
- SCR : capital de solvabilité requis sous Solvabilité II
- VaR : quantile de la charge annuelle agrégée, ici à 99,5 %

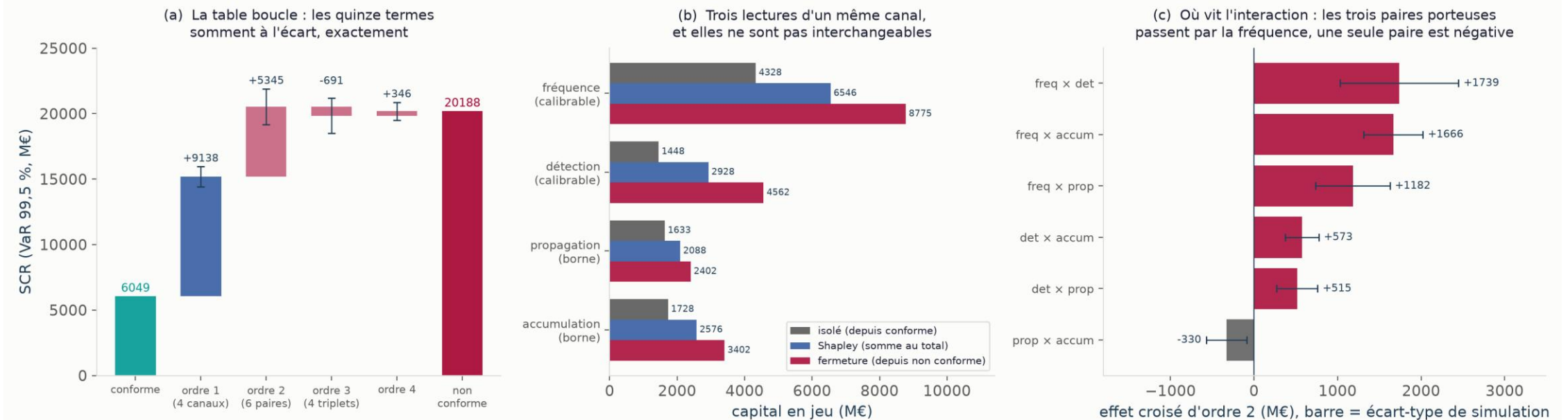
## Quantile de sévérité : quantile d'un sinistre isolé, ce n'est pas une mesure de capital

- GPD : loi de Pareto généralisée, pour les excès au-delà d'un seuil
- Copule : structure de dépendance symétrique, sans direction
- Shapley : convention d'attribution d'un effet total entre leviers
- Cascade : propagation dirigée entre domaines de contrôle

# La table complète des quatre canaux, telle qu'elle est au mémoire

## Les quinze termes, les trois lectures, et où vit l'interaction

**S24 : la table complète des quatre canaux, et où vivent les 5 001 M€ d'interaction**



# L'ensemble d'identification partielle, tel qu'il est au mémoire

## Le pavé, la lecture centrale, la priorité robuste et la hiérarchie

### Z : identification partielle de la contagion dirigée, et bornes de capital

